TEMA 2

Gestión de riesgos y protección de la información

Gestión y Administración de la Ciberseguridad

Máster Universitario en Ciberseguridad · Universidad de Salamanca · Curso 2026-2027

Miguel Puch · mpuchpaino@usal.es

Qué vamos a ver hoy

1. Por qué gestionar riesgos
2. Conceptos fundamentales
3. Activos y clasificación de la información
4. Amenazas y vulnerabilidades
5. Análisis y evaluación del riesgo
6. Tratamiento y riesgo residual
7. Metodologías, marcos y terceros
8. Caso práctico, cierre y bibliografía

Dónde encaja este tema

TEMA 1 · GOBIERNO

Quién decide, con qué criterios y con qué recursos.
La dirección fija el apetito de riesgo y exige rendición de cuentas.
Establece prioridades y responsabilidades.
Deja una pregunta abierta: ¿cuánto riesgo estamos asumiendo?

TEMA 2 · GESTIÓN DE RIESGOS

Responde a esa pregunta con método.
Identifica activos, amenazas y vulnerabilidades.
Mide el riesgo y propone su tratamiento.
Entrega a la dirección la información para decidir.

Gobierno sin gestión de riesgos es una declaración de intenciones; gestión de riesgos sin gobierno es un informe que nadie firma.

0 1

Por qué gestionar riesgos

- No se puede proteger todo igual: los recursos siempre son limitados
- Qué aporta el riesgo: prioridad, proporcionalidad y decisiones justificables
- Del gobierno del Tema 1 a las decisiones del Tema 2

Necesidad de una protección diferenciada según el nivel de riesgo

Presupuesto, personal y tiempo son limitados · la superficie de exposición crece cada año

1. **¿Qué proteger?**
   Los activos y la información realmente críticos para el negocio.
2. **¿Frente a qué?**
   Amenazas realistas para esta organización, no para cualquiera.
3. **¿Con qué prioridad?**
   Según el nivel de riesgo medido, no según la intuición o la moda.
4. **¿Cuánto invertir?**
   Proporcionalidad entre el coste del control y el valor protegido.

Sin análisis de riesgos, la seguridad es una lista de la compra; con él, es una decisión que se puede justificar ante dirección, auditor y regulador.

Caso 1 · Ayuntamiento de Sevilla (septiembre de 2023)

Servicios municipales paralizados durante semanas · vuelta al papel en padrón, multas y nóminas · ransomware LockBit

Qué ocurrió

Acceso con credenciales remotas robadas a un policía local y cifrado de los sistemas por LockBit; el rescate no se pagó.

Servicios a la ciudadanía interrumpidos: padrón, tributos, multas, cita previa y nóminas.

La recuperación de los sistemas se prolongó semanas.

Fuente: comunicaciones públicas del Ayuntamiento de Sevilla e información del CCN-CERT (2023).

Caso 1 · Ayuntamiento de Sevilla (septiembre de 2023)

Por qué abre este tema

Una administración pública está obligada por el ENS a tener un análisis de riesgos: aquí se ve para qué sirve.

El impacto no es solo económico: es interrupción de un servicio público esencial.

La pregunta que hay que saber responder: ¿qué activos eran críticos y qué riesgo se estaba asumiendo?

MAGERIT y el ENS, que veremos hoy, son el marco de referencia para analizar este caso (Ministerio de Hacienda y Administraciones Públicas [MINHAP], 2012).

02

Conceptos fundamentales

- Activo, amenaza, vulnerabilidad, impacto, probabilidad, riesgo y control
- Por qué amenaza, vulnerabilidad y riesgo no son la misma cosa
- La cadena completa aplicada a un incidente real de 2024

Conceptos principales

Concepto	Definición operativa	Ejemplo en una clínica
Activo	Todo lo que tiene valor para la organización	Historial clínico, servidor, personal sanitario
Amenaza	Evento o situación capaz de causar daño	Ransomware, phishing, incendio, error humano
Vulnerabilidad	Debilidad que una amenaza puede aprovechar	Equipos sin actualizar, contraseñas débiles
Impacto	Consecuencia si la amenaza se materializa	Tres días sin acceso a historiales; sanción RGPD
Probabilidad	Verosimilitud de que ocurra en un periodo dado	Alta: campañas de phishing todas las semanas
Riesgo	Combinación de impacto y probabilidad: efecto de la incertidumbre sobre los objetivos	Riesgo alto de pérdida de disponibilidad
Control o salvaguarda	Medida que reduce la probabilidad o el impacto	MFA, copias probadas, formación, segmentación

El escenario de riesgo

Ya lo visteis en el Tema 1 · lo usamos hoy como vocabulario de trabajo

ACTIVO lo que vale · AMENAZA lo que puede dañarlo · VULNERABILIDAD lo que se lo permite · IMPACTO lo que cuesta · RIESGO probabilidad × impacto (modelo simplificado)

LO NUEVO DE HOY: un riesgo no se enuncia con una palabra, se enuncia como un escenario completo

MAL FORMULADO

“Ransomware.”

“El servidor es viejo.”

No dice qué activo afecta, ni cómo, ni qué se pierde: no se puede priorizar ni tratar.

BIEN FORMULADO

“Un grupo de ransomware cifra la base de datos de expedientes aprovechando un acceso remoto sin doble factor, dejando el servicio parado varios días.”

Activo + amenaza + vulnerabilidad + consecuencia, en una frase.

Regla de trabajo para todo el tema: si no puedes escribir el escenario en una frase, aún no tienes un riesgo.

Cadena del riesgo: caso Sevilla

ACTIVO	Padrón, expedientes y sistema de tributos: la información con la que el ayuntamiento presta servicio.
AMENAZA	Grupo de ransomware (LockBit), con posible exfiltración previa. Es externa: no depende del ayuntamiento.
VULNERABILIDAD	Documentado: credenciales remotas robadas. Posibles: sin doble factor, sistemas desactualizados, red sin segmentar. Esto sí depende de la organización.
IMPACTO	Semanas sin servicio a la ciudadanía, coste de reconstrucción y exposición de datos personales.
PROBABILIDAD	Alta: el ransomware contra administraciones locales es una campaña constante, no un caso excepcional.
RIESGO	Alto en este escenario. Si un riesgo alto se conoce y no se trata, eso también es una decisión.

Escenario didáctico: salvo las credenciales robadas, las vulnerabilidades indicadas no son conclusiones forenses confirmadas

0 3

Identificación y valoración de activos

- Qué es un activo y qué tipos hay en una organización
- Las cinco dimensiones: confidencialidad, integridad, disponibilidad, autenticidad y trazabilidad
- Clasificar la información para poder protegerla de forma proporcional

Identificación y clasificación de activos críticos

INFORMACIÓN
Datos de clientes y pacientes, contratos, propiedad intelectual, credenciales, copias

SISTEMAS
ERP, historia clínica, correo, SaaS, entornos de desarrollo

INFRAESTRUCTURA
Servidores, red, nube, puestos de trabajo, OT e IoT

SERVICIOS
Autenticación, conectividad y servicios prestados a clientes

PERSONAS
Conocimiento, perfiles clave, administradores, proveedores con acceso

PROCESOS
Facturación, admisión, cadena de suministro, atención al cliente

INTANGIBLES
Reputación, confianza de los usuarios y cumplimiento normativo

AVISO
El inventario de activos es el entregable que más se descuida. Un activo no inventariado es un activo no protegido.

No todos los activos valen lo mismo: el valor lo marca el impacto en el negocio, no el precio del equipo.

Cuantificación y asignación de valor a los activos

PREGUNTAS QUE DAN EL VALOR

¿Cuánto aguanta el negocio sin este activo: una hora, un día, una semana?
¿Qué pasa si la información se altera sin que nadie lo note?
¿A cuántas personas afectaría una filtración y de qué tipo son sus datos?
¿Qué procesos y qué otros activos dependen de él?
¿Hay obligación legal o contractual asociada?

LO QUE AÑADE MAGERIT

A las tres dimensiones que ya conocéis (C, I, D) suma dos más (MINHAP, 2012):
Autenticidad · poder afirmar que quien actúa es quien dice ser.
Trazabilidad · poder demostrar quién hizo qué y cuándo.
Cada activo se valora por separado en cada dimensión: un activo puede ser crítico en disponibilidad e irrelevante en confidencialidad.

Escala de ejemplo (la define cada organización): 1 despreciable · 3 relevante · 5 crítico para la continuidad o con obligación legal detrás.

La clasificación de la información como fundamento de los controles

Nivel	Qué incluye	Controles típicos asociados
Público	Información difundible sin restricción: web, folletos, notas de prensa	Control de integridad y de publicación; sin cifrado
Uso interno	Documentación operativa, procedimientos, organigramas	Acceso autenticado; no difusión externa
Confidencial	Datos personales, contratos, información económica, código fuente	Acceso por rol, cifrado, registro de accesos, DLP
Secreto / crítico	Categorías especiales (salud, biometría), credenciales, I+D estratégica	Cifrado fuerte, MFA, doble autorización, segregación, retención estricta

Sin clasificación no hay proporcionalidad: se acaba protegiendo igual el folleto comercial que la historia clínica. La clasificación debe ir acompañada de etiquetado, criterios de retención y responsable (propietario) de cada conjunto de información.

Caso 2 · Hospital Clínic de Barcelona (marzo de 2023)

Cientos de intervenciones canceladas · miles de consultas aplazadas · vuelta al papel durante días

Qué ocurrió

Ataque de ransomware atribuido al grupo RansomHouse: cifrado de sistemas y exfiltración de información clínica.
Se cancelaron cientos de operaciones y miles de consultas externas.
Se publicaron datos de pacientes robados; la recuperación llevó semanas.

Por qué es útil aquí

El impacto de un riesgo puede ser asistencial y humano, no solo económico.
El activo crítico no era «el servidor»: era la disponibilidad de la historia clínica.
Datos de salud = categoría especial del RGPD: el impacto regulatorio se multiplica.
La continuidad de negocio forma parte del tratamiento del riesgo.

Fuente: comunicados del Hospital Clínic y de la Agència de Ciberseguretat de Catalunya (2023). Conecta con el Tema 8: continuidad de negocio.

0 4

Amenazas y vulnerabilidades

- Amenazas intencionadas, accidentales y desastres
- Vulnerabilidades técnicas, organizativas y humanas
- Cómo se priorizan hoy: CVE, CVSS, EPSS y el catálogo KEV de CISA

Catálogo de amenazas

INTENCIONADAS

Ransomware y extorsión doble.
Phishing, smishing y fraude del CEO.
Robo de credenciales y acceso no autorizado.
Denegación de servicio (DDoS).
Exfiltración o manipulación de información.
Ataque a la cadena de suministro.
Insider: empleado descontento o con privilegios excesivos.

NO INTENCIONADAS Y DESASTRES

Error humano: envío erróneo, borrado, mala configuración.
Errores de administración y despliegues defectuosos.
Fallos de hardware, software o suministro eléctrico.
Caída de un proveedor cloud o de un servicio esencial.
Incendio, inundación o corte de comunicaciones.

La mayoría de las brechas combinan factor humano y debilidad técnica: rara vez es «solo un hacker» (European Union Agency for Cybersecurity [ENISA], 2024; Verizon, 2025).

Vulnerabilidades más frecuentes

TÉCNICAS

Software y firmware sin actualizar.
Servicios expuestos a Internet sin necesidad.
Ausencia de MFA en accesos remotos y privilegiados.
Configuraciones por defecto o incorrectas, también en la nube.
Red plana, sin segmentación.
Copias no probadas o accesibles desde la red.
Registro y monitorización insuficientes.

ORGANIZATIVAS Y HUMANAS

Sin inventario de activos ni propietario asignado.
Falta de procedimientos y de plan de respuesta.
Formación y concienciación inexistentes.
Proveedores sin cláusulas de seguridad.
Privilegios excesivos y bajas mal gestionadas.

Una vulnerabilidad se evalúa siempre en su contexto y frente a amenazas concretas: por sí sola no es un incidente.

Cómo se priorizan hoy las vulnerabilidades

CVE *Common Vulnerabilities and Exposures*

¿Qué fallo es? El id público de una vulnerabilidad concreta.

Ej.: CVE-2023-34362 (MOVEit) · Lo asigna: MITRE

CVSS *Common Vulnerability Scoring System*

¿Cómo de grave es? Nota técnica de 0 a 10. Mide el daño posible, no si la van a usar.

Ej.: 9,8 = crítica · Lo mantiene: FIRST

EPSS *Exploit Prediction Scoring System*

¿La van a explotar? Probabilidad (0-100 %) de que se ataque en los próximos 30 días.

Ej.: 0,90 = 90 % · Lo publica: FIRST

KEV · CISA *Known Exploited Vulnerabilities (agencia de ciberseguridad de EE. UU.)*

¿Ya la están explotando? Lista de fallos con ataques confirmados en el mundo real.

Si estás en KEV, parchea ya · Lo publica: CISA

Cómo se priorizan hoy las vulnerabilidades

CVSS alto + activo crítico + explotación activa = prioridad máxima

Se combinan, no se multiplican: CVSS (gravedad técnica) + EPSS (probabilidad predictiva; Forum of Incident Response and Security Teams [FIRST], s. f.) + KEV (explotación confirmada; Cybersecurity and Infrastructure Security Agency [CISA], s. f.) + contexto del activo → prioridad de remediación.

Un CVSS 9,8 en un sistema aislado y sin datos puede esperar; un CVSS 7 en el servidor de historiales, no.

Análisis de los casos de estudio

MOVEit Transfer (2023)

Qué fue: vulnerabilidad de inyección SQL (CVE-2023-34362) en un producto de transferencia de ficheros muy extendido.
Explotación: el grupo Cl0p la explotó de forma masiva y automatizada antes de que muchas organizaciones parchearan.
Alcance: más de 2.700 organizaciones y decenas de millones de personas, la mayoría clientes indirectos.
Lección: una vulnerabilidad en un producto compartido se convierte en riesgo sistémico.

Puerta trasera en xz-utils (2024)

Qué fue: un actor pasó más de dos años ganándose la confianza de los mantenedores e introdujo una puerta trasera en las versiones 5.6.0 y 5.6.1 de una biblioteca de compresión de Linux.
Detección: casi por casualidad, por una diferencia de milisegundos en el arranque de SSH.
Alcance: se evitó a tiempo, pero habría comprometido servidores de todo el mundo.
Lección: un SBOM no la habría detectado, pero permite saber si la usas y responder rápido; detectarla exige revisión, procedencia y seguridad del build.

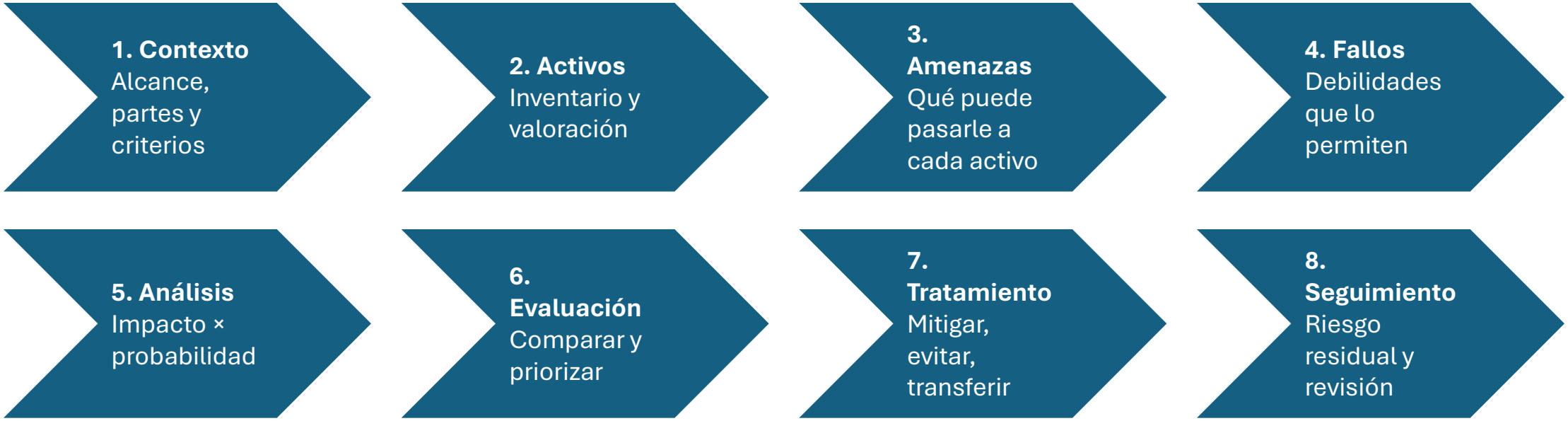
El riesgo entra por donde no lo estás mirando: producto de terceros y cadena de suministro de software.

05

Análisis y evaluación del riesgo

- El proceso paso a paso y los conceptos comunes a las metodologías
- Enfoque cualitativo: escalas y matriz 5 × 5
- Enfoque cuantitativo: SLE, ARO, ALE, ROSI y el modelo FAIR

Pasos del proceso



MAGERIT (MINHAP, 2012) e ISO/IEC 27005 (ISO/IEC, 2022a) cubren este ciclo completo; NIST SP 800-30 (National Institute of Standards and Technology [NIST], 2012) se centra en la evaluación (el tratamiento está en SP 800-37 y 800-39). Comparten conceptos, no el mismo alcance. Y es un ciclo: del paso 8 se vuelve al 1.

Apetito, tolerancia y criterios de aceptación

Apetito de riesgo	Cuánto riesgo está dispuesta a asumir la organización para cumplir sus objetivos. Lo fija la dirección.
Tolerancia	La desviación admisible en un riesgo concreto: hasta 4 horas de parada del portal, nunca más de 24.
Criterios de aceptación	La regla escrita que dice qué se hace con cada nivel de riesgo.

CRÍTICO 20-25
Tratamiento inmediato, con plazo y responsable; escalado a dirección

ALTO 12-19
Plan de tratamiento dentro del trimestre

MEDIO 6-11
Tratar si el coste es razonable; revisión semestral

BAJO 1-5
Aceptar y vigilar

Umbrales de ejemplo, fijados por cada organización. Los criterios se definen ANTES de analizar. Y quien acepta un riesgo es su propietario en el negocio, nunca «el departamento de informática».

Enfoque cualitativo: Escalas y criterios

ESCALA DE PROBABILIDAD

1 · Muy baja — no se espera en 10 años.
2 · Baja — una vez cada 5 años.
3 · Media — probable una vez al año.
4 · Alta — varias veces al año.
5 · Muy alta — mensual o continua.

ESCALA DE IMPACTO

1 · Insignificante — molestia operativa.
2 · Menor — horas en un proceso no crítico.
3 · Moderado — un día de parada, quejas.
4 · Mayor — varios días, brecha notificable.
5 · Crítico — continuidad, sanción grave, daño a personas.

MODELO SIMPLIFICADO: RIESGO = PROBABILIDAD × IMPACTO · valores de 1 a 25 · escalas de ejemplo: cada organización define las suyas

Matriz de riesgo 5 × 5

Probabilidad \ Impacto	1 Insignif.	2 Menor	3 Moderado	4 Mayor	5 Crítico
5 Muy alta	5	10	15	20	25
4 Alta	4	8	12	16	20
3 Media	3	6	9	12	15
2 Baja	2	4	6	8	10
1 Muy baja	1	2	3	4	5

CÓMO SE LEE

Verde (1-5) · Bajo: aceptar y vigilar.
Amarillo (6-11) · Medio: tratar si el coste es razonable.
Naranja (12-19) · Alto: plan de tratamiento con plazo.
Rojo (20-25) · Crítico: acción inmediata y escalado.

Umbrales de ejemplo: los fija cada organización, no ISO, NIST ni MAGERIT. Cuidado: la matriz ordena y comunica, pero no mide. Un 12 no es «el doble de malo» que un 6.

Enfoque cuantitativo: Métricas y estimación del riesgo

AV · valor del activo	La plataforma de citas vale 500.000 € al año en facturación asociada.
EF · factor de exposición	Porcentaje del valor que se pierde en un incidente: 40 %.
SLE = AV × EF	Pérdida esperada por incidente: 500.000 × 0,4 = 200.000 €.
ARO · frecuencia anual	Veces al año que se espera el incidente: 0,5 (uno cada dos años).
ALE = SLE × ARO	Pérdida anual esperada: 200.000 × 0,5 = 100.000 €/año.
ROSI	(ALE antes − ALE después − coste del control) / coste del control.

Sirve para hablar con dirección en su idioma y comparar alternativas.

Exige datos de frecuencia y pérdidas: la falsa precisión es peligrosa.

Ejemplo: ¿merece la pena el control?

Variable	Sin control	Con MFA + copias probadas
AV — valor del activo (plataforma de citas)	500.000 €	500.000 €
EF — porcentaje de pérdida por incidente	40 %	15 %
SLE = AV × EF	200.000 €	75.000 €
ARO — incidentes esperados al año	0,5	0,2
ALE = SLE × ARO	100.000 €/año	15.000 €/año
Coste anual del control	—	25.000 €/año
Ahorro neto esperado	**—**	**60.000 €/año**
ROSI = (ALE_0 − ALE_1 − coste) / coste	**—**	**240 %**

CÓMO DEFENDERLO

El control se justifica porque evita 85.000 € de pérdida esperada al año y cuesta 25.000€.

Un ROSI positivo no basta: hay riesgos que se tratan por obligación legal o por impacto en personas, aunque no salgan “rentables”.

Y al revés: un control rentable sobre un activo irrelevante sigue siendo una mala decisión.

FAIR: descomponer el riesgo en factores

Factor Analysis of Information Risk: método para medir el riesgo en euros, no en “alto/medio/bajo”

RIESGO = FRECUENCIA DE EVENTOS DE PÉRDIDA (LEF) × MAGNITUD DE LA PÉRDIDA (LM)

FRECUENCIA (LEF)

¿Cuántas veces al año sufriremos una pérdida?

TEF (Threat Event Frequency): intentos de ataque al año. Ej.: 10 phishings dirigidos.

Susceptibilidad: % de esos intentos que acaban en pérdida. Ej.: 20 %.

De qué depende: la capacidad del atacante (Threat Capability) frente a la fuerza de tus controles (Resistance Strength).

→ 10 × 20 % = 2 pérdidas al año

MAGNITUD (LM)

¿Cuánto nos cuesta cada una?

Pérdida primaria: lo que paga la empresa directamente: responder al incidente, reponer equipos, horas sin trabajar.

Pérdida secundaria: lo que llega después de terceros: multas (RGPD), demandas, clientes que se van.

Montecarlo: en vez de un valor fijo se usan rangos y se simulan miles de años posibles.

→ Ej.: entre 50.000 y 400.000 € por pérdida

La salida no es un número único, sino un rango con probabilidad: «90 % de confianza en que la pérdida anual esté entre 0,4 y 3,2 M€». Su ventaja real es obligar a explicitar los supuestos, en lugar de esconderlos tras un «riesgo alto».

¿Cualitativo o cuantitativo?

CUALITATIVO

Rápido y barato, aplicable desde el primer día.
Ideal para el primer análisis y para cubrir muchos riesgos a la vez.
Problema: subjetividad. Dos equipos puntúan distinto lo mismo.
Mitigación: escalas bien definidas y valoración en grupo.
Es el uso habitual de MAGERIT, ISO 27005 y NIST 800-30 (ISO/IEC, 2022a; MINHAP, 2012; NIST, 2012).

CUANTITATIVO

Explícito y comparable; habla el idioma de la dirección.
Ideal para decisiones de inversión y sectores exigentes, como el financiero.
Problema: requiere datos, tiempo y madurez.
Mitigación: trabajar con rangos y escenarios, no con cifras únicas.
Enfoque realista: cribar con cualitativo, cuantificar el top 5-10.

No compiten: se combinan. Lo importante no es el método, sino que la decisión quede justificada y trazable.

0 6

Tratamiento del riesgo

- Reducir, evitar, transferir o aceptar: y quién decide cada cosa
- Riesgo inherente, controles y riesgo residual
- Plan de tratamiento, indicadores y revisión periódica

Elegir el tratamiento: criterio, no catálogo

REDUCIR

Controles que bajan probabilidad o impacto

Lo habitual. Se justifica comparando coste del control con reducción esperada.

EVITAR

Eliminar la actividad o el activo

Barato y radical: dejar de almacenar datos que no se necesitan.

TRANSFERIR

Seguro o contrato con un tercero

Traslada parte del coste; no elimina las obligaciones regulatorias ni la responsabilidad propia.

ACEPTAR

Asumirlo por escrito, con fecha

Solo por debajo del criterio aprobado y con revisión.

Cómo se decide cuál aplicar (esto es lo propio del Tema 2)

1. Empezar por los riesgos que superan el criterio de aceptación, no por los más fáciles de arreglar.
2. Comparar el coste anual del control con la pérdida anual esperada que evita; si no se puede cuantificar, comparar esfuerzo con nivel de riesgo.
3. Preferir controles que cubren varios riesgos a la vez (MFA, copias probadas, segmentación) antes que soluciones de un solo uso.
4. Comprobar que el control es operable en esta organización: un procedimiento que nadie va a mantener no reduce riesgo.

Proporcionalidad al contexto: es literalmente lo que pide la guía docente de la asignatura.

Transferir el riesgo: el ciberseguro y sus límites

QUÉ SE PUEDE TRANSFERIR

Parte del impacto económico: peritaje, respuesta al incidente, notificación, defensa jurídica y lucro cesante.

QUÉ NO SE TRANSFIERE

Las obligaciones regulatorias y responsabilidades propias de la organización (p. ej., notificar a la autoridad) y, en la práctica, el daño reputacional.

Caso de referencia · Merck y NotPetya (2017-2024)

El ataque causó a Merck pérdidas superiores a 1.400 millones de dólares. Las aseguradoras se negaron a pagar alegando la exclusión de «actos hostiles o bélicos», al atribuirse el ataque a un Estado. Tras fallos favorables a Merck, se cerró con acuerdo confidencial (enero 2024); el litigio impulsó la revisión de las cláusulas de ciberguerra.

Transferir no es eliminar: el riesgo sigue ahí, solo cambia quién paga parte de la factura.

Riesgo residual: cuánto queda tras los controles

Ejemplo · ransomware en un hospital: inherente 20 (P4 × I5, crítico) → tras los controles → residual 8 (P2 × I4, medio)

CÓMO SE ESTIMA

Se vuelve a puntuar el mismo escenario suponiendo los controles ya implantados y funcionando.
Los controles bajan la probabilidad, el impacto o ambos: hay que decir cuál.
Se estima sobre el control real, no sobre el comprado: si las copias no se prueban, no reducen nada.

EN EL EJEMPLO

Probabilidad 4 → 2: MFA, parches por criticidad, EDR y simulacros de phishing.
Impacto 5 → 4: copias 3-2-1 con una inmutable, restauraciones probadas y segmentación de red.
El impacto baja menos: la exfiltración previa sigue siendo una brecha notificable.

¿Supera el criterio de aceptación? Se trata de nuevo. ¿No? Lo firma su propietario.

Seguimiento y mejora continua

Plan de tratamiento	Para cada riesgo: opción elegida, controles, responsable, plazo, presupuesto y riesgo residual esperado.
Declaración de aplicabilidad	En un SGSI ISO 27001 (ISO/IEC, 2022b), justifica qué controles del Anexo A se aplican y cuáles no. Es la trazabilidad riesgo → control.
Indicadores	Activos inventariados, tiempo medio de parcheo, cobertura de MFA, éxito de restauraciones, clics en phishing simulado.
Cuándo se revisa	Al menos una vez al año; tras un incidente propio o del sector; ante nuevos sistemas, proveedores o normativa.

Un análisis de riesgos que no se revisa caduca en meses y deja de servir para decidir: el ciclo se cierra y vuelve a empezar.

07

Metodologías y marcos

- MAGERIT v3, ISO/IEC 27005:2022 y NIST SP 800-30 Rev. 1
- Qué tienen en común y cuándo conviene cada una
- Encaje con ISO/IEC 27001, NIST CSF 2.0 y el ENS

MAGERIT v3 · España

Metodología de Análisis y Gestión de Riesgos de los Sistemas de Información: el método oficial español

Metodología del Consejo Superior de Administración Electrónica · referencia en el sector público español

Cómo está construida

Tres libros: I. Método (los pasos), II. Catálogo de elementos (listas ya hechas), III. Guía de técnicas (cómo calcular) (MINHAP, 2012).

Catálogos: listas de activos, amenazas y salvaguardas (medidas de protección) ya preparadas y ampliables.

Dependencias: si un servidor guarda datos valiosos, hereda su valor.

PILAR: programa del CCN (Centro Criptológico Nacional) que hace los cálculos (CCN, s. f.-b).

MAGERIT v3 · España

Metodología de Análisis y Gestión de Riesgos de los Sistemas de Información: el método oficial español

Rasgos distintivos

Cinco dimensiones: Confidencialidad, Integridad, Disponibilidad, Autenticidad y Trazabilidad (saber quién hizo qué y cuándo).

Muy guiada: dice paso a paso qué hacer, pero se adapta a cada organización.

ENS (Esquema Nacional de Seguridad): norma obligatoria en la Administración pública; exige analizar riesgos y MAGERIT es la vía habitual (CCN, s. f.-a).

Es la referencia habitual en la Administración española; el ENS exige una metodología reconocida, no necesariamente MAGERIT.

ISO/IEC 27005:2022 · internacional

Norma internacional que explica cómo gestionar los riesgos dentro de la ISO 27001

Guía para la gestión del riesgo de seguridad de la información (ISO/IEC, 2022a) · da soporte a la ISO/IEC 27001

Papel dentro del SGSI

SGSI (Sistema de Gestión de Seguridad de la Información): las políticas y procesos que exige la ISO 27001, la norma que sí se certifica.

Qué aporta: desarrolla las cláusulas 6 y 8 de la 27001, cómo apreciar (identificar y valorar) y tratar los riesgos.

Proceso: contexto → identificación → análisis → evaluación → tratamiento → aceptación → comunicación → seguimiento.

No es certificable: la empresa se certifica en la 27001; la 27005 es su guía de apoyo.

ISO/IEC 27005:2022 · internacional

Norma internacional que explica cómo gestionar los riesgos dentro de la ISO 27001

Novedades de la versión 2022

Escenarios: se puede partir de «qué podría pasar» (p. ej., ransomware en la red), no solo revisar activo por activo.

ISO 31000: norma general de gestión de riesgos de cualquier tipo; ahora comparten vocabulario.

Propietario del riesgo: la persona que responde de un riesgo y decide si se acepta, según criterios fijados de antemano.

Flexible, internacional y conectada con el Anexo A de la ISO 27001:2022, su lista de 93 controles de seguridad (ISO/IEC, 2022b).

NIST SP 800-30 Rev. 1 · Estados Unidos

Guía del NIST (Instituto Nacional de Estándares y Tecnología de EE. UU.) para evaluar riesgos

Guía para realizar evaluaciones de riesgo · SP = Special Publication, la serie de guías de seguridad del NIST

1 · Preparar

Decidir qué se analiza, con qué supuestos y con qué escalas.

2 · Realizar

Identificar quién puede atacar y cómo, qué debilidades hay, y estimar probabilidad e impacto.

3 · Comunicar

Llevar los resultados a quien decide, en un formato que permita priorizar.

4 · Mantener

Revisar la evaluación cuando cambian los sistemas o las amenazas.

NIST SP 800-30 Rev. 1 · Estados Unidos

Guía del NIST (Instituto Nacional de Estándares y Tecnología de EE. UU.) para evaluar riesgos

Rasgos distintivos

Adversario en tres piezas: capacidad (qué sabe hacer), intención (qué quiere) y objetivo (a quién va).

Escalas semicuantitativas: puntos de 0 a 100 que se traducen a «muy bajo … muy alto».

Tablas en los anexos: escalas y listas de amenazas listas para usar, sin partir de cero (NIST, 2012).

Tres niveles: organización, procesos de negocio y sistemas de información.

Encaja con el NIST CSF 2.0 (Cybersecurity Framework, 2024): su función GOVERN pone el riesgo en el centro (NIST, 2024).

Alcances de las metodologías

	MAGERIT v3	ISO/IEC 27005:2022	NIST SP 800-30 Rev. 1
Origen	España · CSAE	Internacional · ISO/IEC	Estados Unidos · NIST
Ámbito típico	Sector público (ENS) y empresa española	SGSI ISO/IEC 27001	Federal EE. UU. y marcos NIST (CSF 2.0)
Enfoque	Basado en activos y dependencias	Basado en activos o en eventos	Basado en eventos y fuentes de amenaza
Escalas	Cualitativa y cuantitativa; catálogos abiertos a ampliación	Flexible: la define la organización	Semicuantitativa con tablas de referencia
Punto fuerte	Muy guiada; herramienta PILAR	Integración directa con el SGSI	Anexos listos para usar

Alcances de las metodologías

Alcance

Conceptos comunes: activo, amenaza, vulnerabilidad, impacto, probabilidad.

MAGERIT e ISO 27005 cubren el ciclo hasta tratamiento y riesgo residual.

NIST SP 800-30 se limita a la evaluación (tratamiento en SP 800-37 y 800-39).

Cómo encaja con el resto de marcos

ISO/IEC 27001:2022

Norma certificable del SGSI. Exige apreciar y tratar el riesgo, y justificar los controles en la Declaración de Aplicabilidad (ISO/IEC, 2022b).

NIST CSF 2.0 (2024)

Seis funciones: GOVERN, IDENTIFY, PROTECT, DETECT, RESPOND, RECOVER. GOVERN eleva el riesgo a decisión de dirección (NIST, 2024).

Cómo encaja con el resto de marcos

ENS · RD 311/2022

Obliga a las administraciones y a sus proveedores a analizar riesgos y aplicar medidas según la categoría del sistema.

NIS2 y DORA

Convierten la gestión de riesgos, incluida la de terceros, en obligación legal con responsabilidad de la dirección. NIS2 en España: transposición incompleta (sept. 2026).

No hay que memorizar tres metodologías, sino reconocer el esquema común y saber cuál toca aplicar en cada contexto.

Riesgo de terceros y cadena de suministro

Del proveedor de servicio

Caída, brecha o ransomware en su infraestructura (Change Healthcare, CrowdStrike).

Del producto de software

Vulnerabilidad o puerta trasera en un componente que tú integras (MOVEit, xz-utils, Log4Shell).

Del acceso concedido

Proveedores con credenciales o conexión a tu red: mantenimiento, consultoría, soporte.

Riesgo de terceros y cadena de suministro

CÓMO SE TRATA

Inventario de proveedores y clasificación por criticidad.

Cláusulas de seguridad y de notificación de incidentes en el contrato.

Evidencias periódicas: certificaciones, informes de auditoría, resultados de pruebas.

SBOM (inventario de componentes de software) y plan de salida o sustitución del proveedor.

El riesgo se hereda, pero el impacto y la responsabilidad no se externalizan. DORA ya lo exige por ley; NIS2 también (en España, pendiente de transposición completa).

Caso 3 · Santander y Ticketmaster (2024)

≈165 organizaciones potencialmente expuestas · volumen de registros no confirmado · sin brecha en Snowflake

Qué ocurrió

Un grupo criminal accedió a entornos de datos alojados en el proveedor cloud Snowflake usando credenciales legítimas robadas previamente con malware.

Las cuentas afectadas no tenían activada la autenticación multifactor.

Entre las víctimas, Banco Santander (datos de clientes y empleados) y Ticketmaster.

Fuente: comunicados de las compañías afectadas y la investigación de Mandiant (Google Cloud) sobre los incidentes asociados a Snowflake (2024).

Caso 3 · Santander y Ticketmaster (2024)

Lectura en clave de riesgo

El modelo de responsabilidad compartida en la nube define quién responde de qué: ignorarlo es un fallo de gobierno.

Una credencial robada a un empleado o contratista es hoy un vector de entrada de primer nivel.

El MFA vuelve a aparecer: Mandiant constató que las cuentas comprometidas no lo tenían activado.

El daño reputacional recae sobre todo en la marca visible para el cliente.

Protección de la información basada en riesgos

EL ORDEN CORRECTO

1. Identificar y clasificar la información y los activos.
2. Analizar y evaluar los riesgos sobre ellos.
3. Decidir el tratamiento según los criterios aprobados.
4. Seleccionar e implantar los controles necesarios.
5. Medir el riesgo residual y revisar.

Cada control puede justificarse señalando el riesgo que reduce.

Protección de la información basada en riesgos

EL ORDEN EQUIVOCADO (Y HABITUAL)

Comprar la herramienta de moda y buscarle después justificación.

Copiar la lista de controles de otra organización.

Aplicar el Anexo A entero «por si acaso».

Resultado: gasto desproporcionado en unos riesgos, indefensión en otros y controles que nadie mantiene.

Conexión: Tema 3 estándares · Tema 4 obligaciones legales · Tema 6 políticas y controles · Tema 7 auditoría

0 8

Caso práctico: Metalgar (caso ficticio)

- Una pyme industrial con mucha dependencia y poco gobierno
- Ocho preguntas para diagnosticarla, en grupos de tres o cuatro personas
- Puesta en común y respuesta orientativa

El supuesto: Metalgar, fabricante de componentes, 120 empleados

Caso ficticio · Dos plantas y un almacén · produce para tres clientes grandes del sector del automóvil · sin personal propio de informática

1. Los planos y los presupuestos de cliente están en un servidor de ficheros compartido por toda la empresa.
2. Las máquinas de planta se controlan con equipos antiguos que el fabricante ya no actualiza.
3. Un proveedor externo gestiona los sistemas y entra en remoto con una cuenta de administrador compartida.
4. Hay copias de seguridad en un disco conectado permanentemente al mismo servidor.

El supuesto: Metalgar, fabricante de componentes, 120 empleados

5 La red es plana: oficinas, planta y wifi de visitas comparten el mismo segmento.

6 Un cliente acaba de exigir por contrato notificar cualquier incidente en 24 horas.

7 No hay inventario de activos ni nadie con la seguridad asignada por escrito.

Trabajo en grupo

1. ¿Cuáles son los activos críticos y cómo los valoraríais en cada dimensión?
2. ¿Qué amenazas identificáis? Distinguid intencionadas, accidentales y de proveedor.
3. ¿Qué vulnerabilidades existen, técnicas y organizativas?
4. Escribid tres riesgos como escenario completo, en una frase cada uno.
5. Situadlos en la matriz 5 × 5 y justificad probabilidad e impacto.
6. ¿Qué medidas propondríais y en qué orden? ¿Cuáles cuestan poco o nada?
7. ¿Aceptaríais algún riesgo? ¿Quién debería firmar esa aceptación?
8. ¿Cambia algo la cláusula contractual de notificar en 24 horas?

Se evalúa la cadena: activo → amenaza → vulnerabilidad → impacto → riesgo → tratamiento

Solución orientativa (I): activos, amenazas y vulnerabilidades

Activo	Amenaza principal	Vulnerabilidad que la habilita	Impacto (dimensión)
Planos y presupuestos de cliente	Exfiltración y extorsión	Servidor compartido sin control de acceso por perfiles	Confidencialidad · pérdida de contrato
Servidor de ficheros	Ransomware	Copia conectada al propio servidor · red plana	Disponibilidad · integridad
Equipos de control de planta	Parada de producción	Sistemas sin soporte del fabricante, sin segmentar	Disponibilidad · entregas comprometidas
Acceso remoto del proveedor	Compromiso del tercero	Cuenta de administrador compartida y permanente	Confidencialidad · trazabilidad
Capacidad de detección y respuesta	Incidente no detectado a tiempo	Sin detección ni procedimiento de respuesta	Legal · reputacional: incumplir la cláusula de 24 h

Error frecuente del alumnado: enumerar «ransomware» como vulnerabilidad o «el servidor» como riesgo. Conviene corregirlo en el momento: es lo que consolida el vocabulario. La notificación en 24 h no es un activo: es un requisito contractual del contexto que eleva el impacto.

Solución orientativa (II): priorización y tratamiento

Riesgo (escenario)	P	I	Nivel	Tratamiento propuesto
Ransomware cifra el servidor de ficheros y también la copia conectada	4	5	**20 · Crítico**	Reducir: copia inmutable y aislada, prueba de restauración mensual, MFA, segmentación
Un tercero compromete la cuenta compartida del proveedor	3	4	**12 · Alto**	Reducir y transferir: cuentas nominales, acceso temporal, registro y cláusulas en contrato
Exfiltración de planos y presupuestos de cliente	3	5	**15 · Alto**	Reducir: permisos por perfil, clasificación de la información, registro de accesos
Parada de planta por equipos sin soporte	2	5	**10 · Medio**	Reducir: segmentar la red industrial y plan de contingencia; sustitución a medio plazo
No detectar a tiempo y incumplir la notificación en 24 h	3	3	**9 · Medio**	Reducir: registro centralizado, procedimiento de respuesta y responsable designado

Medidas de coste casi nulo que salen siempre: desconectar la copia del servidor, dar de baja la cuenta compartida del proveedor, activar MFA y nombrar un responsable. Riesgo residual esperado tras el plan: de crítico a medio; la aceptación final la firma la gerencia, no el proveedor informático.

Ideas clave del tema

1. No se puede proteger todo por igual: el riesgo es lo que permite priorizar.
2. Activo, amenaza, vulnerabilidad, impacto y riesgo son conceptos distintos.
3. Sin inventario ni clasificación de la información, el análisis de riesgos es ficción.
4. El riesgo combina impacto y probabilidad: cualitativo, semicuantitativo o cuantitativo.
5. Los criterios de aceptación se fijan antes de analizar y los aprueba la dirección.
6. Cuatro opciones: reducir, evitar, transferir o aceptar. Transferir no elimina la responsabilidad.
7. Los controles reducen el riesgo, casi nunca lo eliminan: queda el riesgo residual.
8. MAGERIT, ISO 27005 y NIST 800-30 comparten conceptos, no el mismo alcance.
9. El riesgo de terceros es uno de los vectores principales y una exigencia legal creciente.
10. Primero el riesgo, después el control: nunca al revés.

Ante cualquier organización: ¿qué riesgos ha medido, quién los ha aceptado y cómo lo sabe?

Competencias y próximas sesiones

COMPETENCIAS DE LA FICHA

H3 · Analizar y evaluar riesgos, identificar debilidades y proponer soluciones.

C5 · Examinar aspectos interdisciplinares: gestión de riesgos, ética y privacidad.

C2 · Identificar amenazas y vulnerabilidades comunes.

H8 · Análisis, resolución de problemas y comunicación.

Objetivo: aplicar MAGERIT, ISO 27005 y NIST 800-30 y proponer planes de tratamiento proporcionados al contexto.

HACIA DÓNDE VAMOS

Tema 3 · Marco NIST y estándares internacionales.

Tema 4 · Legal: RGPD, LOPDGDD, ENS, NIS2 y DORA.

Tema 5 · Ética y privacidad.

Tema 6 · Políticas, procedimientos y controles.

Tema 7 · Auditoría de la ciberseguridad.

Tema 8 · Incidentes y continuidad de negocio.

La próxima sesión traduce estos riesgos en estándares y controles concretos.

Para ampliar: bibliografía y recursos

Normas y metodologías del tema

Centro Criptológico Nacional. (s. f.-b). *PILAR: Procedimiento Informático y Lógico de Análisis de Riesgos* [Software]. CCN-CERT.

ISO/IEC. (2022a). *Information security, cybersecurity and privacy protection — Guidance on managing information security risks* (ISO/IEC 27005:2022).

ISO/IEC. (2022b). *Information security, cybersecurity and privacy protection — Information security management systems — Requirements* (ISO/IEC 27001:2022).

Ministerio de Hacienda y Administraciones Públicas. (2012). *MAGERIT – versión 3.0. Metodología de análisis y gestión de riesgos de los sistemas de información*.

National Institute of Standards and Technology. (2012). *Guide for conducting risk assessments* (NIST SP 800-30 Rev. 1). https://doi.org/10.6028/NIST.SP.800-30r1

National Institute of Standards and Technology. (2024). *The NIST Cybersecurity Framework (CSF) 2.0* (NIST CSWP 29). https://doi.org/10.6028/NIST.CSWP.29

Recursos en línea

Centro Criptológico Nacional. (s. f.-a). *Guías CCN-STIC*. CCN-CERT. https://www.ccn-cert.cni.es

Cybersecurity and Infrastructure Security Agency. (s. f.). *Known exploited vulnerabilities catalog*. https://www.cisa.gov/known-exploited-vulnerabilities-catalog

European Union Agency for Cybersecurity. (2024). *ENISA threat landscape 2024*. https://www.enisa.europa.eu

Forum of Incident Response and Security Teams. (s. f.). *Exploit Prediction Scoring System (EPSS)*. https://www.first.org/epss

Instituto Nacional de Ciberseguridad. (s. f.). *Avisos de seguridad*. INCIBE. https://www.incibe.es

SANS Institute. (s. f.). *Security policy templates*. https://www.sans.org/information-security-policy

Verizon. (2025). *2025 data breach investigations report*. https://www.verizon.com/business/resources/reports/dbir

Miguel Puch · mpuchpaino@usal.es · material y enlaces en Studium

Bibliografía básica

- Stallings, W. (2017). *Network Security Essentials*. Pearson.
- Anderson, R. (2020). *Security Engineering*. Wiley.
- Jouini, M., & Abeni, A. (2013). *Cyber Security and IT Infrastructure Protection*. Springer.

Miguel Puch · mpuchpaino@usal.es · enlaces y material en Studium